

Gruppenaufgabe 4

Klassifizierungskriterien für Applikationen und Datenbestände

Szenario

Die «PharmaSwiss GmbH», ein mittelständisches Pharmaunternehmen mit 200 Mitarbeitenden in Zug, muss im Rahmen einer Audit-Vorbereitung erstmals eine vollständige Klassifizierung aller Applikationen und Datenbestände nach Volumen, Periodizität und Zugriffssicherheit durchführen. Als internes IT-Projektteam sollen Sie die Klassifizierungskriterien auf die wichtigsten Systeme anwenden, daraus betriebliche Anforderungen (RTO/RPO) ableiten und eine Schutzbedarfsanalyse erstellen.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Applikationen und Datenbestände systematisch nach Volumen, Periodizität und Zugriffssicherheit klassifizieren und bewerten.
- Aus den Klassifizierungsergebnissen konkrete RTO- und RPO-Werte für geschäftskritische Systeme ableiten und begründen.
- Eine Schutzbedarfsanalyse mit den Dimensionen Vertraulichkeit, Verfügbarkeit und Integrität durchführen und dokumentieren.

Arbeitsauftrag

Identifizieren Sie in Ihrer Kleingruppe die fünf wichtigsten Applikationen und Datenbestände der «PharmaSwiss GmbH». Klassifizieren Sie jede Applikation nach Volumen, Periodizität und Zugriffssicherheit. Leiten Sie für jede Applikation RTO- und RPO-Werte ab und erstellen Sie eine Schutzbedarfsanalyse mit Bewertung in den Dimensionen Vertraulichkeit, Verfügbarkeit und Integrität.

Ergebnis

Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie Ihre Klassifizierungsergebnisse, die abgeleiteten RTO/RPO-Werte und die Schutzbedarfsanalyse für die drei kritischsten Applikationen vorstellen und begründen.

Musterlösung A | Gruppenaufgabe 4 | Klassifizierungskriterien für Applikationen und Datenbestände

Ansatz: Strukturiert-analytisch

1. Identifikation der Top-5-Applikationen

Für die PharmaSwiss GmbH identifizieren wir folgende fünf geschäftskritischen Applikationen und Datenbestände:

Nr.	Applikation	Beschreibung
A1	ERP-System (SAP)	Finanz-, Einkaufs- und Produktionsplanung
A2	Laborinformationssystem (LIMS)	Verwaltung von Laboranalysen, Prüfberichten und Chargenfreigaben
A3	Dokumentenmanagementsystem (DMS)	Verwaltung regulatorischer Dokumente, SOPs, Validierungsdokumente
A4	E-Mail-System (Exchange)	Interne und externe Geschäftskommunikation
A5	Personalinformationssystem (HR)	Personalstammdaten, Lohnabrechnungen, Zeiterfassung

2. Klassifizierung nach Volumen, Periodizität und Zugriffssicherheit

2.1 Klassifizierung nach Datenvolumen

Applikation	Aktuelles Volumen	Jährliches Wachstum	Bewertung
A1 – ERP	500 GB	+15 %/Jahr	Mittel
A2 – LIMS	2 TB	+25 %/Jahr	Hoch
A3 – DMS	5 TB	+20 %/Jahr	Sehr hoch

A4 – E-Mail	1 TB	+10 %/Jahr	Mittel
A5 – HR	50 GB	+5 %/Jahr	Gering

Das DMS und das LIMS haben das grösste Volumen und das stärkste Wachstum, was erhöhte Anforderungen an Speicherkapazität und Backup-Bandbreite stellt.

2.2 Klassifizierung nach Periodizität (Änderungshäufigkeit)

Applikation	Änderungsfrequenz	Bewertung	Konsequenz
A1 – ERP	Kontinuierlich (Transaktionen)	Sehr hoch	Kurze Sicherungsintervalle oder kontinuierliche Replikation
A2 – LIMS	Täglich (neue Analysen)	Hoch	Tägliche Sicherung, idealerweise zweimal täglich
A3 – DMS	Wöchentlich (neue Dokumente)	Mittel	Tägliche Sicherung genügt
A4 – E-Mail	Kontinuierlich	Sehr hoch	Kontinuierliche Replikation oder stündliche Sicherung
A5 – HR	Monatlich (Lohnlauf)	Gering	Tägliche Sicherung, Speziälsicherung vor/nach Lohnlauf

2.3 Klassifizierung nach Zugriffssicherheit

Applikation	Vertraulichkeit	Verfügbarkeit	Integrität	Gesamtbewertung
A1 – ERP	Hoch	Sehr hoch	Sehr hoch	Sehr hoch
A2 – LIMS	Sehr hoch	Hoch	Sehr hoch	Sehr hoch
A3 – DMS	Hoch	Hoch	Sehr hoch	Hoch
A4 – E-Mail	Mittel	Hoch	Mittel	Mittel
A5 – HR	Sehr hoch	Mittel	Hoch	Hoch

3. Ableitung von RTO- und RPO-Werten

Applikation	RPO (max. Datenverlust)	RTO (max. Ausfallzeit)	Begründung
A1 – ERP	1 Stunde	4 Stunden	Kerngeschäftsprozess; jede Stunde Ausfall = CHF 10 000 Verlust
A2 – LIMS	4 Stunden	8 Stunden	Chargenfreigaben zeitkritisch; regulatorische Anforderungen (GMP)
A3 – DMS	24 Stunden	24 Stunden	Dokumente sind selten zeitkritisch, aber regulatorisch essenziell
A4 – E-Mail	1 Stunde	4 Stunden	Kommunikationsfähigkeit geschäftskritisch
A5 – HR	24 Stunden	48 Stunden	Nur zum Lohnlauf-Zeitpunkt kritisch, sonst geringere Dringlichkeit

4. Schutzbedarfsanalyse

Applikation	Vertraulichkeit	Verfügbarkeit	Integrität	Gesamtschutzbedarf	Massnahmen
A1 – ERP	Hoch	Sehr hoch	Sehr hoch	Sehr hoch	Kontinuierliche Replikation, Georedundanz, Offline-Backup, MFA
A2 – LIMS	Sehr hoch	Hoch	Sehr hoch	Sehr hoch	Verschlüsselung, Audit-Trail, zweimal tägliches Backup, Validierung
A3 – DMS	Hoch	Hoch	Sehr hoch	Hoch	Versionierung, tägliches Backup, Zugriffsrechte, Prüfsummen

A4 – E-Mail	Mittel	Hoch	Mittel	Mittel	Stündliche Sicherung, Spamfilter, Archivierung
A5 – HR	Sehr hoch	Mittel	Hoch	Hoch	Dateiverschlüsselung, MFA, monatliche Speziialsicherung

5. Empfehlungen für das Sicherungskonzept

Basierend auf der Klassifizierung leiten wir folgende Sicherungsstrategie ab:

1. **ERP (A1):** Kontinuierliche Datenbankreplikation auf einen zweiten Standort. Zusätzlich tägliches Vollbackup und wöchentliches Offline-Backup. RPO 1h / RTO 4h erfordert eine Hot-Standby-Lösung.
2. **LIMS (A2):** Zweimal tägliches Backup mit Prüfsummenvalidierung. GMP-konforme Dokumentation jedes Sicherungslaufs. Immutable Storage für Chargenfreigabedaten.
3. **DMS (A3):** Tägliches inkrementelles Backup mit wöchentlichem Vollbackup. Versionierungssystem mit mindestens 30 Tagen Rückhaltung. Prüfsummen für Integritätssicherung.

6. Fazit

Die systematische Klassifizierung zeigt, dass die fünf Applikationen der PharmaSwiss GmbH sehr unterschiedliche Anforderungen haben. Eine Einheitsbehandlung wäre entweder zu teuer (wenn das höchste Niveau für alle gilt) oder zu riskant (wenn das niedrigste Niveau für alle gilt). Die Klassifizierung nach Volumen, Periodizität und Zugriffssicherheit ermöglicht eine bedarfsgerechte, kosteneffiziente und regulatorisch konforme Sicherungsstrategie.

Musterlösung B | Gruppenaufgabe 4 | Klassifizierungskriterien für Applikationen und Datenbestände

Ansatz: Praxisnah-narrativ

1. Die Herausforderung: Fünf Systeme, fünf verschiedene Welten

Wenn man durch die PharmaSwiss GmbH geht, sieht man auf den ersten Blick ein modernes Unternehmen: SAP-Terminals in der Produktion, Labormitarbeitende am LIMS, das Management in Outlook. Aber hinter den Kulissen werden alle diese Systeme gleich behandelt – einmal täglich gesichert, alle auf demselben Speicher, alle mit denselben Zugriffsrechten.

Das mag für ein Start-up funktionieren. Für ein Pharmaunternehmen, das GMP-reguliert ist, Swissmedic-Audits besteht und mit hochsensiblen Forschungsdaten arbeitet, ist es ein Risiko. Der bevorstehende Audit zwingt uns, Ordnung zu schaffen. Also: Welche Systeme haben wir, und wie unterschiedlich sind sie wirklich?

2. Unsere fünf Kernapplikationen unter der Lupe

Das ERP-System (SAP): Das Herzstück des Unternehmens.

Alles läuft durch SAP: Bestellungen, Rechnungen, Produktionsplanung, Lagerbestände. Das System ist 24/7 im Einsatz. Wenn SAP ausfällt, steht die Produktion still. Die Daten ändern sich kontinuierlich – jede Buchung, jede Wareneingang, jede Rechnung. Das Datenvolumen ist mit 500 GB moderat, aber die Änderungsfrequenz ist extrem hoch.

Was bedeutet das für die Sicherung? Wir können uns keinen Datenverlust von mehr als einer Stunde leisten. Eine tägliche Sicherung um Mitternacht ist nicht gut genug – wenn der Server um 17:00 Uhr ausfällt, verlieren wir einen ganzen Arbeitstag an Buchungen. Also brauchen wir entweder eine kontinuierliche Replikation oder mindestens stündliche Sicherungen. Und SAP muss innerhalb von vier Stunden wieder laufen – sonst stehen 200 Mitarbeitende ohne Arbeitswerkzeug da.

Das Laborinformationssystem (LIMS): Wo Datenintegrität Leben rettet.

Im LIMS werden Laboranalysen, Prüfberichte und Chargenfreigaben verwaltet. In der Pharmabranche sind diese Daten mehr als nur Dateien – sie sind der Beweis, dass unsere Medikamente sicher sind. Wenn ein Prüfbericht verlorengeht oder manipuliert wird, können wir eine ganze Charge nicht freigeben. Das kostet nicht nur Geld, sondern kann Menschenleben gefährden.

Die Anforderungen sind klar: Höchste Integrität (Daten dürfen nicht verändert werden können), höchste Vertraulichkeit (Forschungsdaten sind Geschäftsgeheimnisse) und hohe Verfügbarkeit. Das Volumen ist mit 2 TB beachtlich und wächst schnell – jede Analyse erzeugt neue Datensätze. Sicherung: Mindestens zweimal täglich, mit Prüfsummenvalidierung bei jedem Lauf. Und die Daten müssen auf Immutable Storage liegen – einmal geschrieben, nicht mehr veränderbar.

Das Dokumentenmanagementsystem (DMS): Das regulatorische Gedächtnis.

Im DMS liegen alle SOPs (Standard Operating Procedures), Validierungsdokumente und regulatorischen Einreichungen. Dieses System hat das grösste Volumen (5 TB) und wächst stetig. Aber die Änderungsfrequenz ist niedriger als bei SAP oder LIMS – neue Dokumente kommen wöchentlich hinzu, bestehende werden selten geändert. Trotzdem ist die Integrität entscheidend: Wenn bei einem Audit ein validiertes Dokument fehlt oder verändert wurde, ist das ein schwerwiegender Befund.

Sicherung: Tägliches Backup genügt, aber mit Versionierung – jede Änderung muss nachvollziehbar sein. Die Aufbewahrungsfrist beträgt mindestens 15 Jahre (Pharma-Regulierung). Ein Tagesverlust ist verkraftbar, da neue Dokumente nur selten zeitkritisch sind. RPO: 24 Stunden, RTO: 24 Stunden.

Das E-Mail-System: Unterschätzter Kommunikationskanal.

E-Mail ist das Kommunikationsmittel Nr. 1 – intern und extern. Verträge werden per E-Mail besprochen, Audit-Anfragen beantwortet, Kundenreklamationen dokumentiert. Das Volumen ist mit 1 TB moderat, die Änderungsfrequenz hoch. Der Schutzbedarf ist mittelmässig – E-Mails enthalten selten hochsensible Daten, aber der Verlust der Kommunikationshistorie wäre schmerzhaft.

Sicherung: Stündliche Sicherung, dazu ein E-Mail-Archiv mit Langzeitaufbewahrung. RPO: 1 Stunde. RTO: 4 Stunden. Wenn wir länger als einen halben Tag keine E-Mails senden können, verlieren wir Aufträge.

Das Personalinformationssystem (HR): Klein, aber hochsensibel.

Mit nur 50 GB ist das HR-System das kleinste unserer fünf Systeme. Aber es enthält die sensibelsten Daten: Lohnabrechnungen, Sozialversicherungsnummern, Gesundheitsdaten, Leistungsbeurteilungen. Diese Daten sind gemäss DSG besonders schützenswert.

Die Änderungsfrequenz ist gering – grosse Datenänderungen gibt es nur zum Monatslohnlauf. Aber die Vertraulichkeit ist maximal: Nur drei Personen dürfen auf dieses System zugreifen. Sicherung: Tägliches Backup, plus Speziälsicherung vor und nach jedem Lohnlauf. Dateiverschlüsselung und Multi-Faktor-Authentifizierung sind Pflicht.

3. Die Gesamtübersicht: Nicht alles ist gleich

Fassen wir zusammen. Unsere fünf Systeme könnten unterschiedlicher nicht sein:

System	Volumen	Änderung	Vertraulichkeit	Verfügbarkeit	RPO	RTO
SAP	Mittel	Sehr hoch	Hoch	Sehr hoch	1h	4h
LIMS	Hoch	Hoch	Sehr hoch	Hoch	4h	8h
DMS	Sehr hoch	Mittel	Hoch	Hoch	24h	24h
E-Mail	Mittel	Sehr hoch	Mittel	Hoch	1h	4h
HR	Gering	Gering	Sehr hoch	Mittel	24h	48h

4. Was das für die Backup-Strategie bedeutet

Die Tabelle zeigt: Wir brauchen mindestens drei verschiedene Sicherungsstrategien:

Strategie «Gold» (SAP, E-Mail): Kontinuierliche oder stündliche Sicherung, Hot-Standby-System für schnelle Wiederherstellung. RPO $\leq$ 1h, RTO $\leq$ 4h. Das ist teuer, aber notwendig.

Strategie «Silber» (LIMS, DMS, HR): Tägliche Sicherung, georedundante Kopie. Für LIMS zusätzlich zweimal täglich und Immutable Storage. Für HR zusätzlich Verschlüsselung und Spezial-Backup zum Lohnlauf.

Für alle: Offline-Backup. Mindestens wöchentlich eine Offline-Kopie aller Systeme im Tresor. Das schützt gegen Ransomware und ist nicht verhandelbar.

5. Die Schutzbedarfsanalyse: Drei Dimensionen, ein klares Bild

Für den Audit müssen wir jedes System in drei Dimensionen bewerten:

Vertraulichkeit: Am höchsten bei LIMS (Forschungsdaten) und HR (Personaldaten). Diese Systeme brauchen Verschlüsselung und strenge Zugriffskontrollen.

Verfügbarkeit: Am höchsten bei SAP. Ohne SAP steht die Produktion. Ein Hot-Standby-System ist hier die einzige Option, die den RTO von 4 Stunden realistisch einhalten kann.

Integrität: Am höchsten bei LIMS und DMS. Manipulierte Labordaten oder veränderte SOPs können zu Produktrückrufen und Patientengefährdung führen. Immutable Storage und Prüfsummen sind Pflicht.

6. Fazit und Botschaft an das Management

Die Klassifizierung zeigt: Unsere fünf Kernsysteme haben grundlegend unterschiedliche Anforderungen. Ein «One-size-fits-all»-Backup ist nicht nur ineffizient, sondern regulatorisch nicht tragbar. Die vorgeschlagene Differenzierung in Gold- und Silber-Strategien plus Offline-Backup stellt sicher, dass jedes System den Schutz erhält, den es braucht – nicht mehr und nicht weniger.

Die Investitionskosten für die Umstellung betragen geschätzt CHF 45 000 (Hot-Standby für SAP, Immutable Storage für LIMS, Offline-Backup-Infrastruktur). Im Vergleich zu den potenziellen Kosten eines Datenverlusts in einem GMP-regulierten Umfeld – Produktrückrufe, Audit-Befunde, Reputationsschäden – ist das eine bescheidene Investition.

</content>

</document>

Beide Dateien für **Unit 2** stehen nun als separate Canvas-Dokumente zum Herunterladen bereit:

Datei	Inhalt	Format
Unit2_Inhaltsfolien.md	Agenda, 24 Inhaltsfolien (4 × 6), Zusammenfassung	Markdown
Unit2_Gruppenaufgaben_Musterloesungen.md	4 Gruppenaufgaben, 8 Musterlösungen (4 × A + B)	Markdown